DisputeDesk AI — Phase 4

Buyer Experience & Dispute Clarity

Baseline 5145cbe (master) **Date** 3 November 2026 **Status** committed as 90cbe40, not pushed

Summary. Buyers now see each of their own disputes with a plain-language status explanation, the usual stages with the current one marked, next steps, information worth having, safe-contact guidance and an explicit "not on record" list. Every block is labelled "From the record", "General guidance" or "Not on record". An optional "Explain in plain language" button returns checked AI wording, or the labelled standard explanation when AI is off, fails, or any check fails. No merchant order, evidence, customer message or draft reaches the buyer or the buyer's Gemini request. No live PayPal or Gemini calls were made.

159/159	56/56	2 × 30/30	clean	pass
server tests (was 139)	client tests (was 53)	browser checks, 4173 and 5173	both type checks	production build

1. Files changed

File	Change
`server/src/buyer.ts` (new)	Rule-based buyer guidance built only from buyer-visible fields; buyer Gemini request; buyer wording checks; standard explanation fallback.
`server/src/buyer.test.ts` (new)	11 tests: field isolation, statuses and stages, missing and unknown data, self-check of every guidance line, AI checks and fallbacks.
`client/src/Buyer.tsx` (new)	Buyer list and detail, stage tracker, source tags, explanation view, loading, empty and error states.
`server/src/db.ts`	Migration 2: `disputes.create_time` column; audit log rebuilt with the new `buyer_explanation_generated` event. Version 1's event list is frozen so its SQL never changes.
`server/src/validate.ts` , `store.ts`	Opened date kept (strict ISO date and time, real calendar day), stored and read back. Fixes the missing "Opened" date.
`server/src/app.ts`	Buyer list adds `guidance` ; new `POST /api/buyer/explain` .
`server/src/assist.ts`	Existing check patterns exported for reuse; no behaviour change.
`shared/types.ts`	`BuyerStage` , `BuyerGuidance` , `BuyerDispute` , `BuyerExplanation` .
`client/src/App.tsx` , `sandbox.ts` , `styles.css`	BuyerHome uses the new view; fetch helpers with response checks; tag and stage styles; old list-only buyer view removed.
Tests: `app.test.ts` , `db.test.ts` , `store.test.ts` , `evidence.test.ts` , `ui.test.ts`	New route, role-matrix and privacy tests; migration tests; opened-date tests; UI tests.
`README.md` , `CLAUDE.md`	Buyer features, migration 2, audit event, demo script step.

2. API changes (additive only)

- `GET /api/buyer/disputes` (buyer): each dispute gains `guidance` and, where the record has it, `create_time`. Existing fields are unchanged; order, evidence and customer message are still absent.
- `POST /api/buyer/explain` `{ source, dispute_id }` (buyer only): returns `{ origin: "ai" | "rules", model, paragraphs, fallback_reason, flags }`. Another account's dispute answers 404, identical to a missing one, and is audited as `dispute_access_denied`. Merchant and admin get 403; a sandbox source gets 403. Gemini errors give the standard explanation with status 200. Audited as `buyer_explanation_generated` with detail `rules` or `ai, <model>`.
- Buyers are never told how the server is configured: the "AI off" message is generic, not the merchant-facing reason.

3. Privacy, fairness and AI safeguards

- **The server is the authority.** The explain route reuses `findDispute` and `canAccess`; the browser only names a dispute.
- **Field isolation by type.** Guidance takes a `BuyerRecord` (source, ID, reason, status, amount, opened date) and cannot read merchant fields. A test proves guidance is identical when the merchant's evidence and order change.
- **Gemini sees only** status, reason, amount, opened date and the rules' guidance, with no dispute ID. Record text that reads like instructions is withheld.
- **Checks on every AI paragraph:** promises or predictions of refunds or outcomes; legal claims; blame; dates, numbers, names or carriers not on record; delivery, shipping and tracking claims; claims about the seller's records; echoed instructions; talk of submission. Any failure replaces the whole answer with the standard explanation. The failed text is never returned.
- **No invented facts.** Stages are labelled "the usual order of a dispute, not a recorded history"; only the opened date comes from the record. Deadline and outcome are listed as not on record. An unknown status code marks no stage as current.
- **Neutral wording.** A test runs every rule-written line, for every status and reason, through the same checks as AI wording.
- **Mutation checks:** disabling the promise check, or leaking the customer message into the buyer view, each made 2 tests fail. Both were reverted.

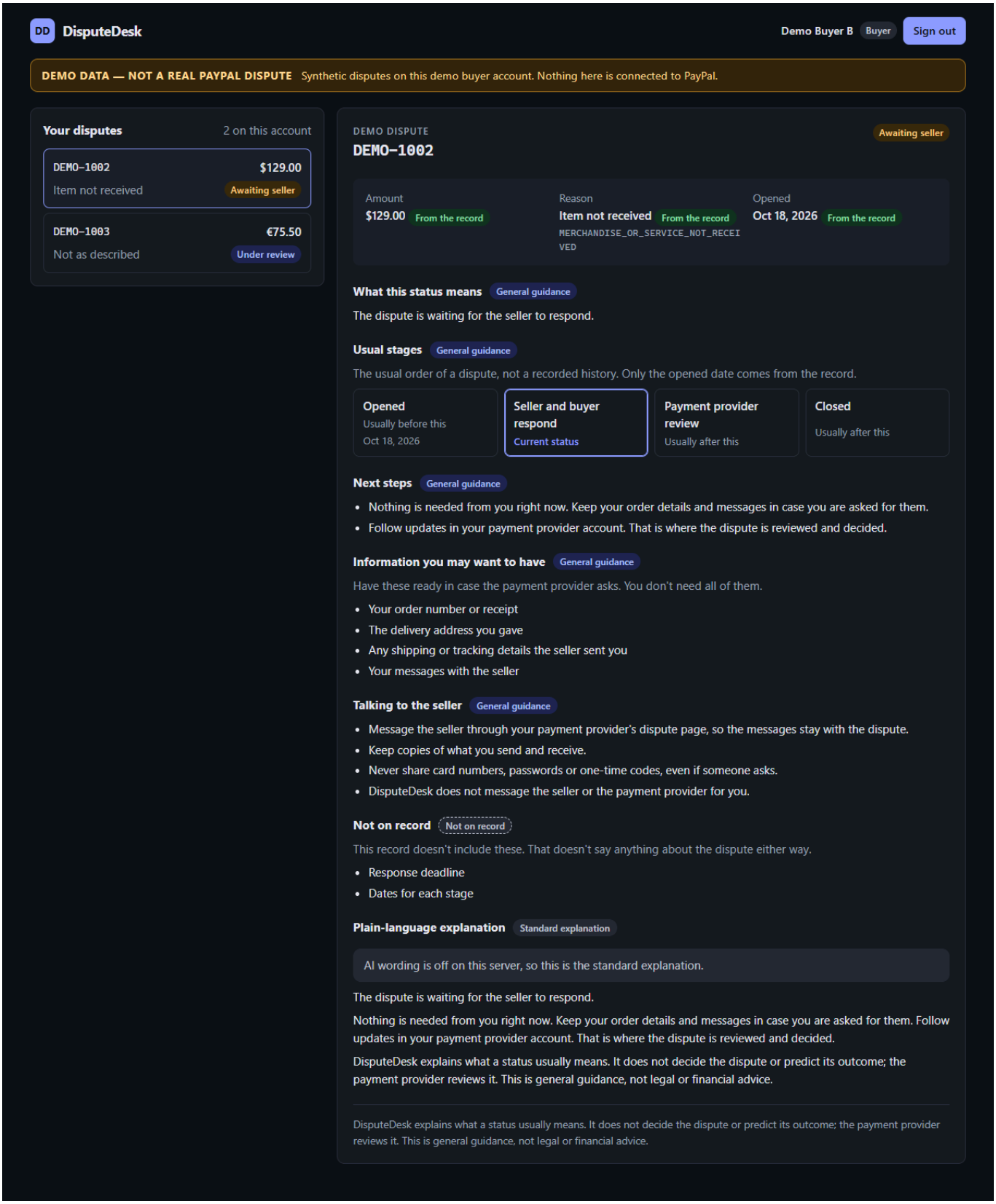
4. Database

- Migration 2 runs in one transaction. The upgrade test confirms audit rows are copied unchanged, ids keep counting, append-only triggers still block update and delete, and unknown events are still refused.
- Version 1's SQL hash is pinned in a test, so a released migration can't be edited by accident.
- The live file database upgraded in place on restart: schema versions 1 and 2, all 28 earlier audit rows kept, and opened dates filled for DEMO-1002 and DEMO-1003. DEMO-1001 has no opened date and stays empty.

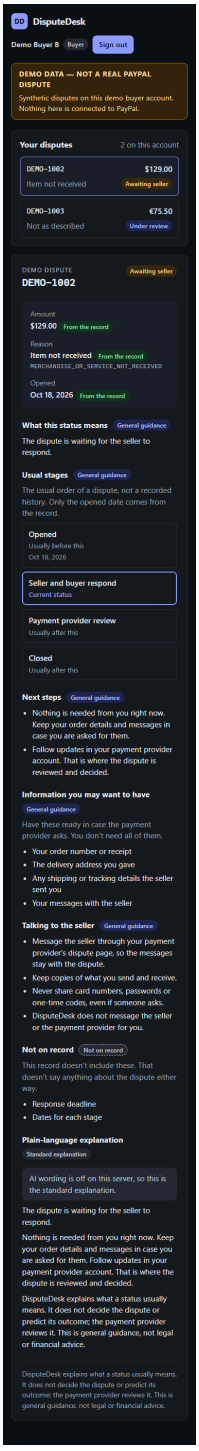
5. Browser evidence

Headless Chrome, signed in as each demo role on the production build (port 4173) and the dev server (port 5173). Both give the same 30 results:

- PASS page headers: X-Frame-Options, nosniff, Referrer-Policy
- PASS signed out: /api/auth/me is 401
- PASS signed out: /api/health is 401
- PASS cookie flags: HttpOnly=true Secure=true SameSite=Strict Path=/; no Domain attribute (host-only); browser storage host localhost
- PASS document.cookie is empty (HttpOnly)
- PASS API headers through the proxy
- PASS Merchant A sees DEMO-1001 and DEMO-1002 only
- PASS Merchant A: DEMO-1003 is 404
- PASS Merchant A: health 200
- PASS Merchant A: analysis and validation example render
- PASS page fetch to another origin: blocked
- PASS cross-site form POST to sign-out is refused: 403
- PASS and the session is unaffected
- PASS sign-out removes the cookie from the browser
- PASS replaying the signed-out cookie: 401
- PASS Buyer B sees DEMO-1002 and DEMO-1003 only
- PASS Buyer B: no merchant order, tracking, message, evidence or draft on the page
- PASS Buyer B: one current stage, marked with aria-current=step
- PASS Buyer B: source labels shown
- PASS Buyer B: explaining DEMO-1001 is 404
- PASS Buyer B: explanation shown (standard)
- PASS Buyer B at 1280px: no horizontal scroll
- PASS Buyer B at 375px: no horizontal scroll
- PASS Buyer B at 320px: no horizontal scroll
- PASS Buyer B: health and merchant list 403
- PASS Admin: no Generate AI draft button
- PASS Admin: AI route 403
- PASS Admin: DELETE accounts 404
- PASS CSP violations since the last page load: none
- PASS console errors other than expected 4xx: none



Desktop, 1280 px. DEMO-1002: source tags, current stage marked, response deadline not on record, and the standard explanation labelled because AI is off on this server.



Phone, 375 px. The detail stacks below the list, with no horizontal scroll (also checked at 320 px).

6. Remaining risks

- **AI path not seen live.** Gemini is off on this server (`GEMINI_MODEL` is invalid), and live calls need your approval. The AI path is tested with a mocked Gemini only.
- **The checks are strict.** Real AI wording may often fall back to the standard text, for example when it mentions delivery for a not-received dispute. This fails safe, but can make the button look unhelpful.
- Guidance text is general and not taken from PayPal's own policy. It is worded as guidance, with a not-legal-advice notice.
- Buyer-side conflict detection is limited: the only known contradictions are inside merchant evidence, which buyers must not see.

- Deviation from the plan: the buyer's own message is not used in guidance, so the buyer response stays free of record text.
- There is no rate limit on `/api/buyer/explain` beyond the one-request-at-a-time guard per dispute.

7. Git status

Committed locally on `master` as `90cbe40` (parent `5145cbe`): 19 files changed, 1135 insertions, 104 deletions, including the 3 new files `server/src/buyer.ts`, `server/src/buyer.test.ts` and `client/src/Buyer.tsx`. Nothing is pushed. `.env`, `server/data/` and `reports/` were not staged; a scan of the staged changes found no keys, tokens or passwords. No `.env` values, tokens or passwords appear in the code, this report or its screenshots.